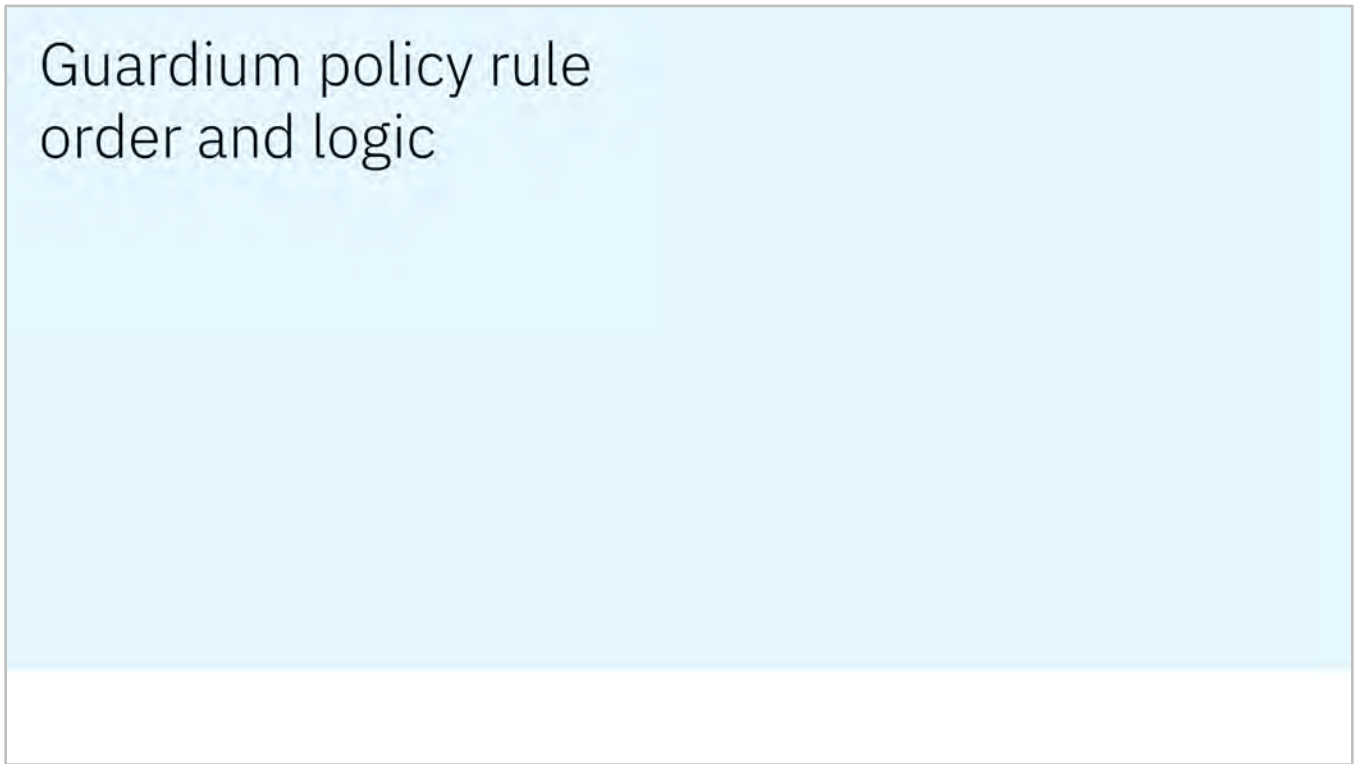


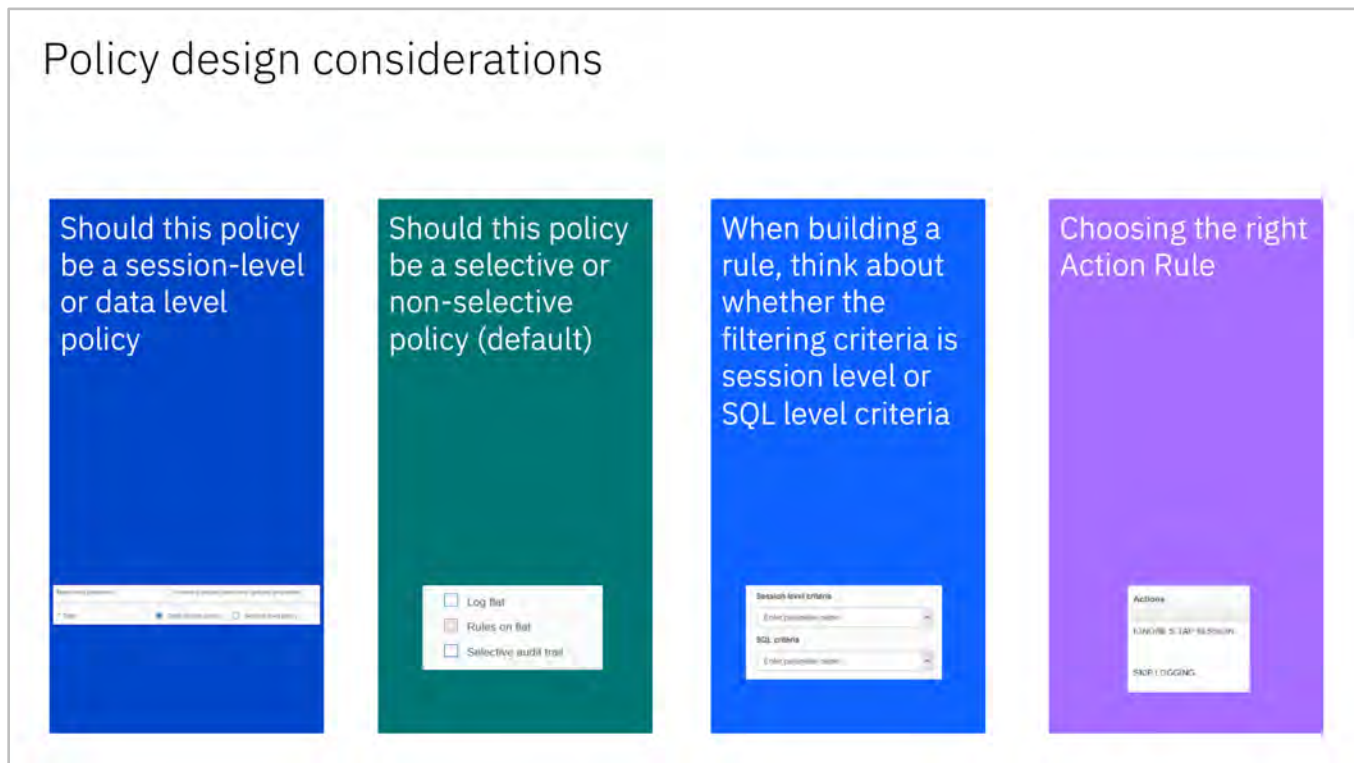
Guardium policy rule order and logic

Figure: Guardium policy rule order and logic



Generally, an implementation includes multiple rules. These rules can all be in one policy or in multiple policies. In either case, structure your rules carefully so that they are properly applied. Incorrect rule order can result in a data security vulnerability. In this lesson, you learn about rule order, default behavior, and policy logic.

Figure: Policy design considerations



When preparing to design a policy, there are several considerations.

- Should this be a Session Level or Data Level policy? A session level policy fires only on session level criteria such as Client IP, OS User, Database User, and so on.
- Should this be a Selective or Non-Selective policy (default)? Usually, use a selective policy to ignore most of the database traffic, and when an organization knows exactly what to monitor.

When building a rule, think about whether the filtering criteria is session level or SQL level criteria:

- **Session level** criteria include Server IP, Client IP, Database Protocol, Database User, OS User
- **SQL level** criteria include table (object) name, column (field) name, command (Select, Update, Delete)

It is important to choose the correct Action Rule. Remember, within a policy, rules are evaluated in the order in which they appear, as each element of traffic is analyzed. The policy rule determines the type of actions. If needed, consider using Policy Analyzer to evaluate the frequency in which rules fire.

Figure: Rule order (1 of 2)

Rule order (1 of 2)

Rule order can affect whether policy rules fire correctly



Order	Rule type	Rule name	Tags	Criteria	Actions	Continue to next rule	Installed
1	Access	Ignore S-TAP session for trusted users		Severity = Info, Database user in group Lab Trusted Users	IGNORE S-TAP SESSION	☐	
2	Access	Alert on access to sensitive objects		Category = Access, Severity = High, Object in Group Sensitive Objects, Command in Group DML Commands	LOG MASKED DETAILS, ALERT PER MATCH	☐	
3	Exception	Failed login alert		Category = Exception, Severity = Medium, Database user = ., Exception type = LOGIN_FAILED, Minimum point = 3, Reset interval = 5	ALERT PER MATCH	☐	

Within a policy, Guardium evaluates rules in the order in which they are listed, and each element of traffic is analyzed. The order of the rules ensures that the rules work as designed.

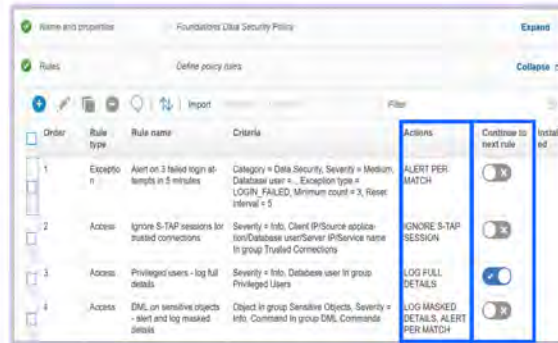
Usually, access rules are first, followed by exception and extrusion rules. This logic applies to data security policies. For session level policies, add only session type rules.

Figure: Rule order (2 of 2)

Rule order (2 of 2)

Actions and settings that can affect the policy logic

- Multiple actions
- Continue to next rule
- Ignore session rules
- Exception versus access rules
- Analyzer rules



Rule actions also affect the policy logic:

- **Multiple actions:** If two actions for the same criteria are required, use multiple actions.
- **Continue to next rule:** If two requirements exist that do not have the same criteria but do have some overlap, use the Continue to next rule checkbox. By default, after a rule is triggered, processing stops. If this checkbox is selected, rule testing continues with the next rule, regardless of whether this rule is satisfied. If Continue to next rule is not selected (the default), no additional rules are tested for the current transaction when this rule is satisfied.

Note: The Continue to next rule setting applies to access rules that follow access rules and to exception rules that follow exception rules. It does not apply to an exception rule that follows an access rule or an access rule that follows an exception rule.

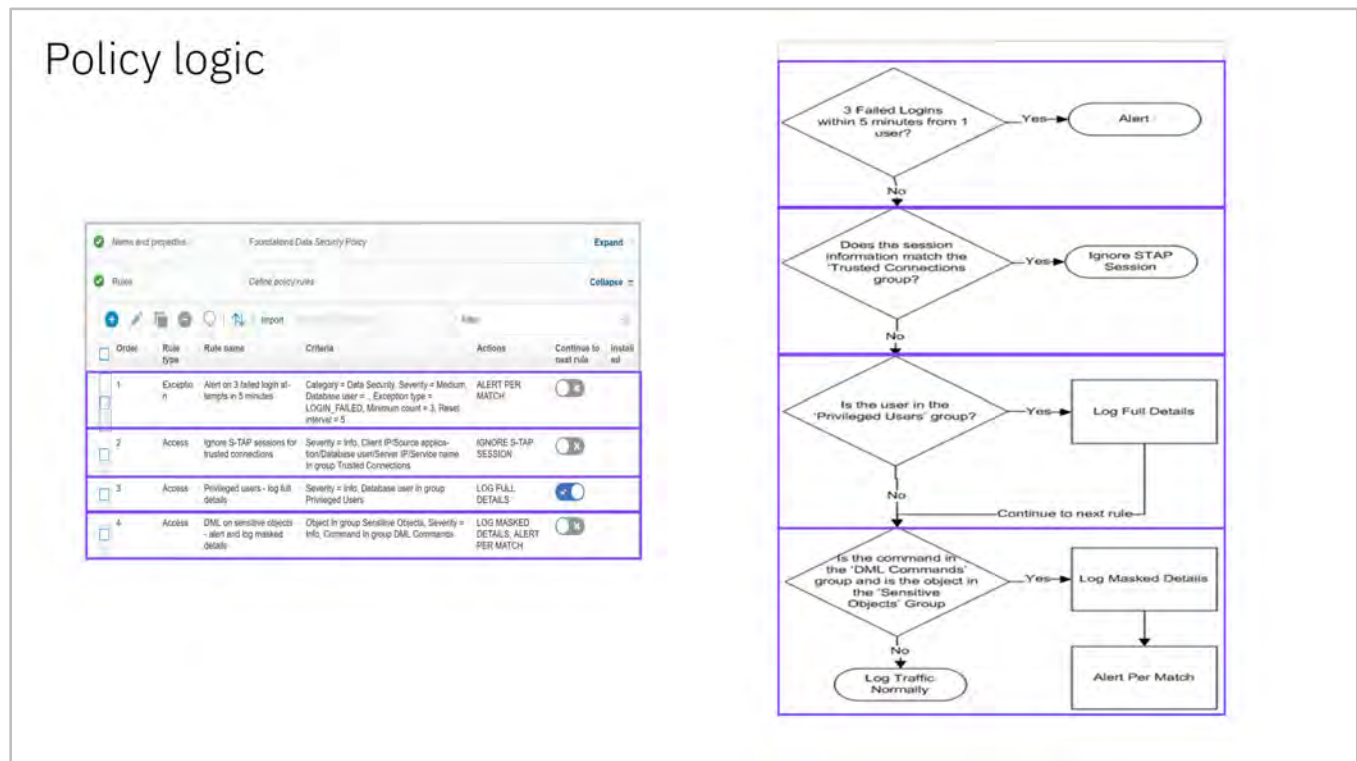
Extrusion rules are processed regardless of the end of an access or exception rule that precedes the extrusion rule.

- **Ignore session rules:** In general, ignore session rules are the first access rules. An exception to this general practice rule is a “catch-all” rule at the end of a policy that ignores all sessions that did not match the previous. To temporarily prevent an ignore session rule from firing, place it after an Allow rule. Implementing the ignore session rule means that the session is logged, but the activity is not.

Note: Remember, after a session is ignored, no activity within that session is processed.

- **Exceptions and access rules:** These rules are mutually exclusive because they examine different sides of the traffic flow. Usually, these rule types do not have much of an effect on each other.
- **Analyzer rules:** Certain rules can be applied at the analyzer level. Examples of analyzer rules are user-defined character sets, source program changes, and issuing watch verdicts for firewall mode. When rules are applied at the analyzer level, decisions can be made at an earlier stage.

Figure: Policy logic



Remember, the rule order designs the logic to ensure the rules work properly. In the example on the slide, the incoming database traffic is evaluated as follows:

1. Have there been 3 failed logins within 5 minutes from a single user? If yes, alert. If no, go to the next rule. Because this rule is an exception rule and the remaining rules are access rules, this rule can be placed anywhere.
2. Does the session information match the Trusted Connection group? If yes, use Ignore S-TAP Session. If no, go to the next rule. This is the first access rule because all the trusted connections are ignored. If this rule is placed lower in the rule order, some rules might fire inappropriately.
3. Is the user in the Privileged User group? If yes, use Log Full Details and Continue to next rule. If the Continue to next rule checkbox is not selected, the policy stops at this rule for all privileged user activity. Therefore, to ensure that the fourth rule is processed for privileged users, specify to continue to the next rule.
4. Is the object in the Sensitive Objects group and is the command in the DML Commands group? If yes, log masked details and alert per match.

If the user is a privileged user, the log full details action from the third rule takes precedence. If none of the above are matched, log traffic normally.

